PRADITA University

IT40813 · IT Governance, Risk & Compliance

Alat GRC dan Peta Jalan Tata Kelola Terpadu

Pertemuan 14

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. GRC Terpadu
3. Alat GRC
4. Peta Jalan
5. Perubahan dan Budaya
6. Presentasi kepada Direksi
7. Aktivitas
8. Ringkasan dan Latihan

PRADITA University

Semua angka benar di babnya masing-masing. Apakah semuanya muat dalam Rp10 miliar?

Tujuan Pembelajaran

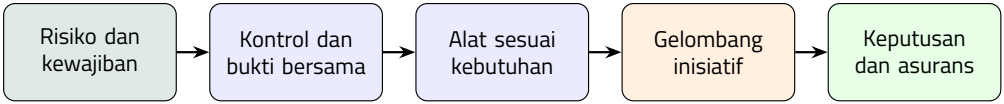
- Membandingkan pilihan alat GRC, dari spreadsheet sampai platform terintegrasi, berdasarkan kebutuhan dan kematangan organisasi.
- Menyusun peta jalan GRC bertahap yang selaras dengan peta jalan transformasi digital.
- Mempertahankan rekomendasi tata kelola, risiko, dan kepatuhan di depan pemangku kepentingan.

Masalah: 20 Spreadsheet, Banyak Versi

PRADITA University

- Misalkan register risiko, kepatuhan, dan temuan audit tersimpan dalam 20 spreadsheet.
- Satu akun vendor dicatat sebagai tiga masalah dengan pemilik berbeda.
- Unit TI melaporkan 108 dari 108 akun, padahal populasinya 120 akun.
- Bab 1 sampai Bab 13 menghasilkan angka yang belum pernah dijumlahkan.
- Hasil kerja: peta jalan tiga tahun, pilihan alat, dan paket keputusan C4.

Alur Keputusan Bab Ini

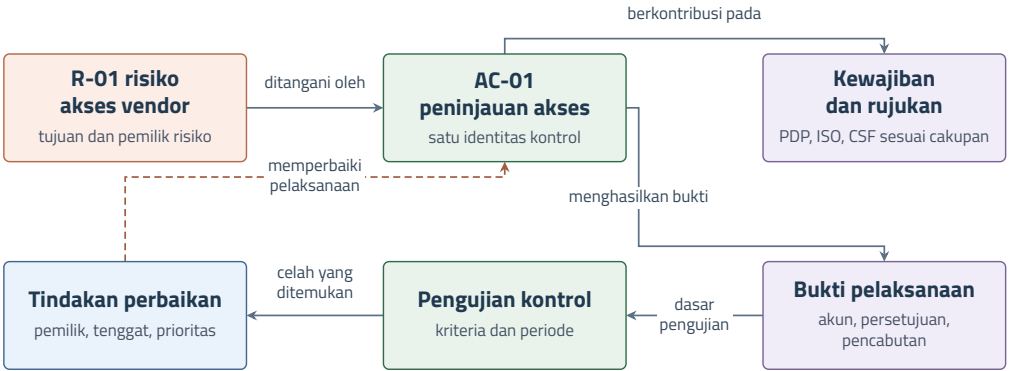


Seluruh angka, pemetaan, dan anggaran Medikara merupakan pengandaian pembelajaran.

Diagram Konsep Bab 14

PRADITA University

Satu kontrol terhubung ke risiko, kewajiban, dan bukti



Pemakaian ulang bukti memerlukan kecocokan periode, sistem, dan kriteria. Alat dipilih setelah identitas serta proses disepakati.

Satu Identitas untuk Satu Objek

PRADITA University

- GRC terpadu menghubungkan tujuan, risiko, kewajiban, kontrol, bukti, uji, dan tindakan.
- Analogi katalog perpustakaan: satu buku pada banyak kategori tetap satu buku.
- Permintaan bukti turun dari 276 menjadi 92 per tahun, hemat 368 jam atau Rp22,08 juta.
- Tiga baris tindakan pada akun vendor menjadi satu: ACT-AC01-01.
- Biaya penyamaan: 196 objek kali 30 menit, atau 98 jam senilai Rp5,88 juta.

196 Objek yang Perlu Identitas (Misalkan)

PRADITA University

Objek	Kode	Jumlah	Asal
Risiko	R-01 sampai R-12	12	Bab 5
Kewajiban	K-01 sampai K-16	16	Bab 3
Kebijakan	KB-01 sampai KB-09	9	Bab 8, Bab 11
Target	T-01 sampai T-24	24	Bab 8, Bab 10
Celah	G-01 sampai G-06, CP-01 sampai CP-07	13	Bab 6, Bab 7
Hubungan pemasok	Register, termasuk V-01 sampai V-06	40	Bab 9
Sistem AI	AI-01 sampai AI-06	6	Bab 11
Catatan pemrosesan	Enam proses inti	28	Bab 7
Baris BIA	Lima rumah sakit dan fasilitas lain	36	Bab 10
Indikator	IK-01 sampai IK-12	12	Bab 13
Jumlah		**196**	

Bukti: 60 + 144 + 260 = 464 per tahun.

Memeriksa Tiga Acuan AC-01

Acuan	Isi yang diminta	Dijawab AC-01	Belum dijawab
UU 27/2022 Pasal 39, K-01	Mencegah data pribadi diakses secara tidak sah	Akun tanpa dasar dicabut	Autentikasi, jejak aktivitas, akun bersama
UU 27/2022 Pasal 35, 36, 37	Langkah teknis, kerahasiaan, pengawasan pihak terlibat	Sebagian pengawasan akun vendor	Tingkat keamanan; 11 butir perjanjian
ISO/IEC 27001:2022 Annex A 5.18	Pengelolaan hak akses; naskah berbayar	Peninjauan dan pencabutan	SoA, penilaian risiko, kontrol lain
NIST CSF 2.0 PR.AA-05	Izin dalam kebijakan, dikelola, ditegakkan, ditinjau, hak paling kecil, pemisahan tugas	Ditinjau, sebagian ditegakkan	Hak paling kecil, pemisahan tugas

Kontribusi berarti menjawab sebagian isi. Pemenuhan berarti seluruh isi terjawab dan terbukti.

Kapan Bukti Boleh Dipakai Ulang

PRADITA University

- Empat syarat: periode, cakupan sistem, kriteria, dan keandalan cocok.
- Misalkan EV-AC01-2026-10 mencatat 114 dari 120 akun pada Oktober 2026.
- Bukti itu sah untuk IK-07, yaitu 95 persen. Bukti itu belum cukup untuk menutup TA-01.
- Laporan 108 dari 108 tampak 100 persen, tetapi penyebutnya salah.
- Pemetaan yang rapi tidak membuktikan efektivitas kontrol.

Empat Fungsi dan Tiga Pilihan

Fungsi: register, alur kerja, pengelolaan bukti, pelaporan, disertai jejak perubahan.

Pilihan	Kekuatan	Kebutuhan pengelolaan	Cocok bila
Spreadsheet terstruktur	Cepat dimulai, mudah ditinjau	Versi, akses, validasi data	Definisi baru disepakati
Sumber terbuka	Dapat disesuaikan	Operasi, pembaruan, keahlian	Ada pengelola tetap
Platform komersial	Dukungan, fungsi terintegrasi	Lisensi, kontrak, portabilitas	Alur lintas unit stabil

Analogi gudang: sistem mahal tetap salah bila nomor barang dan penanggung jawabnya tidak tertib. Platform yang membaca daftar yang sama tetap melaporkan 108 dari 108.

Biaya Tiga Tahun pada Periode Sama (Misalkan)

Juta rupiah	Tahun 1	Tahun 2	Tahun 3	Jumlah	Hitungan
Spreadsheet	50	30	30	110	$20 + 3 \times 30$
Sumber terbuka	120	60	60	240	$60 + 3 \times 60$
Platform	250	100	100	450	$150 + 3 \times 100$
Bertahap	**50**	**120**	**60**	**230**	$(20 + 30) + (60 + 60) + 60$

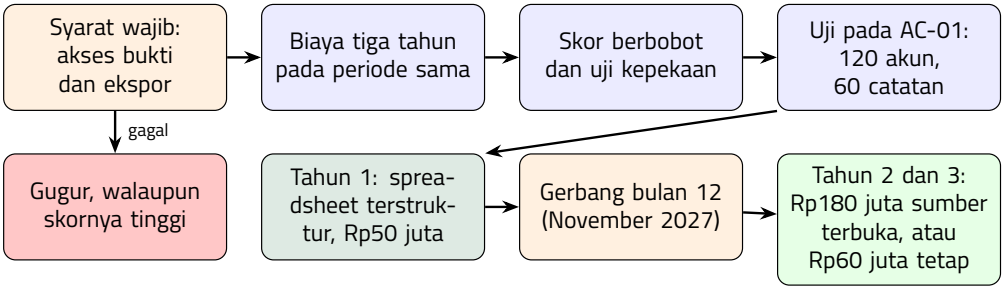
- Lisensi nol bukan biaya nol: pengelola 1.000 jam, atau Rp60 juta per tahun.
- CISO Assistant Community memakai AGPL v3. Eramba punya edisi Community.
- Angka ini asumsi, bukan klaim harga produk.

Syarat Wajib Lebih Dahulu, Skor Kemudian

Kriteria	Bobot	Spreadsheet	Sumber terbuka	Platform
Pembatasan akses bukti	Wajib	Ya, bersyarat	Belum diuji	Belum diuji
Ekspor data lengkap	Wajib	Ya	Belum diuji	Belum diuji
Kecocokan proses	25	3	4	5
Biaya tiga tahun	25	5	3	2
Kemudahan pengelolaan	20	4	2	3
Jejak perubahan	15	2	4	5
Portabilitas	15	4	4	3
Skor berbobot	100	**3,70**	**3,35**	**3,55**

Bobot biaya 15 dan jejak perubahan 25: skor menjadi 3,40, 3,45, dan 3,85. Urutan berbalik.

Urutan Memilih Alat



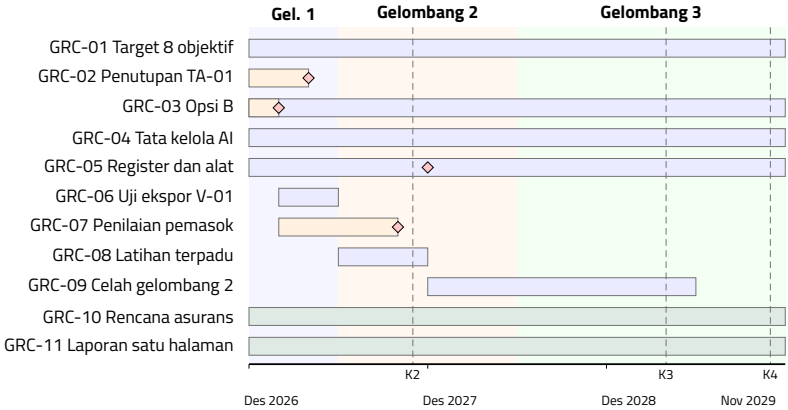
Kasus Medikara: Alat Dipilih Bertahap

- Tahun 1: spreadsheet terstruktur, Rp20 juta awal dan Rp30 juta pengelola, atau 500 jam.
- Dua puluh berkas dibekukan. Bukti sensitif disimpan terpisah.
- Gerbang bulan 12: objek berpemilik, akses bersyarat, jam pengelola.
- Bila lulus: sumber terbuka, cadangan Rp180 juta untuk Tahun 2 dan 3.
- *Tradeoff*: jejak perubahan tetap lemah selama setahun.

Urutan Mengikuti Ketergantungan

- Analogi renovasi: pengecatan tidak didahulukan dari perbaikan kebocoran.
- Penilaian vendor 484 jam harus selesai sebelum K2 Oktober 2027, jadi mulai Februari 2027.
- Latihan terpadu Rp180 juta menunggu tahap kedua opsi B: baru 3 dari 5 rumah sakit lulus.
- *Quick win*: perbaikan awal yang bernilai dan layak, bukan yang paling mudah.
- Bulan 1 adalah Desember 2026, dan bulan 36 adalah November 2029.

Peta Jalan GRC Tiga Tahun (Misalkan)



Gelombang 1 menutup yang jatuh tempo, gelombang 2 menguji kemampuan, gelombang 3 memperluas. PP 33/2026 hanya dipantau pada bulan 2.

Inisiatif dan Gerbang: Gelombang 1

Kode	Inisiatif	Bulan	Pemilik	Gerbang
GRC-01	Target delapan objektif	1 sampai 36	Pemilik objektif	T-01 sampai T-24
GRC-02	Penutupan TA-01	1 sampai 4	Kepala operasi TI	120/120 akun, 60/60 catatan, 30/30 sampel
GRC-03	Opsi B	1 sampai 36	Kepala operasi TI	Bulan 2: 5 dari 5 rumah sakit, 9 dari 9 uji
GRC-04	Tata kelola AI, KB-09	1 sampai 36	Direktur pelayanan	6 baris ditinjau tiap triwulan
GRC-05	Register dan alat	1 sampai 36	Kepala risiko	Bulan 3: 196 objek; bulan 12: alat
GRC-06	Uji ekspor V-01	3 sampai 6	Pengelola vendor	Rekam sintetis terbaca

Inisiatif dan Gerbang: Gelombang 2 dan 3

Kode	Inisiatif	Bulan	Pemilik	Gerbang
GRC-07	Penilaian 40 pemasok	3 sampai 10	Pengelola vendor	40 dari 40 sebelum K2
GRC-08	Latihan terpadu dua layanan	7 sampai 12	Kepala operasi TI	RTO dan kapasitas minimum
GRC-09	Celah G-04, G-06, CP-02, CP-07	13 sampai 30	Pemilik SIMRS	Peran baku; satu inventaris
GRC-10	Rencana asurans	1 sampai 36	Kepala audit internal	Temuan lolos uji ulang
GRC-11	Laporan satu halaman	1 sampai 36	Kepala risiko	Direksi memutuskan

Biaya Penuh dan Uang Baru (Juta Rupiah)

Baris	Tahun 1	Tahun 2	Tahun 3	Jumlah
GRC-01 Target delapan objektif	720,00	720,00	720,00	2.160,00
GRC-03 Opsi B	480,00	480,00	480,00	1.440,00
GRC-04 Waktu staf tata kelola AI	182,76	1,92	1,92	186,60
GRC-04 Alat alternatif	240,00	240,00	240,00	720,00
GRC-05 Register dan alat GRC	50,00	120,00	60,00	230,00
GRC-06 Uji ekspor V-01	60,00	0,00	0,00	60,00
GRC-08 Latihan terpadu	180,00	0,00	0,00	180,00
Biaya penuh	**1.912,76**	**1.561,92**	**1.501,92**	**4.976,60**
Dikurangi nilai jam kerja	412,38	197,94	197,94	808,26
Uang baru	**1.500,38**	**1.363,98**	**1.303,98**	**4.168,34**

Asal Tiap Baris Biaya

- GRC-01: $4 \times 120 + 4 \times 60 = 720$. AC-01 Rp60 juta sudah di dalam DSS05.
- GRC-03: $120 + 180 + 180 = 480$, sesuai Bab 10 dan Bab 13.
- GRC-04: 3.046 jam senilai Rp182,76 juta ditambah Rp240 juta, atau Rp422,76 juta.
- Lisensi AI-01 belum termasuk. Alat alternatif dianggap langganan tahunan.
- Dua Rp180 juta berbeda: tahap opsi B dan latihan terpadu GRC-08.

Beban Jam Tiga Tahun (Misalkan)

PRADITA University

Baris	Asal	Objektif	Tahun 1	Tahun 2	Tahun 3	Jumlah
AC-01 pada 120 akun	Bab 6	DSS05	144	144	144	432
144 uji pemulihan	Bab 6	DSS04	432	432	432	1.296
Latihan pemberitahuan	Bab 7, Bab 8	MEA03	96	96	96	288
260 tinjauan catatan aktivitas	Bab 8	DSS05	520	520	520	1.560
BIA 36 baris	Bab 10	DSS04	216	0	0	216
Tabletop 5 kali	Bab 10	DSS04	35	35	35	105
Beban Bab 8 sesudah Bab 10			**1.443**	**1.227**	**1.227**	**3.897**
Rapat tiga forum	Bab 8	APO12	400	400	400	1.200
5 DPIA	Bab 7	APO14	360	0	0	360
Register 40 pemasok	Bab 9	APO10	484	0	0	484
Tinjauan 5 pemasok	Bab 9	APO10	160	160	160	480
Pembaruan 40 server	Bab 9	APO13	480	480	480	1.440
Di dalam GRC-01			**3.327**	**2.267**	**2.267**	**7.861**
Tata kelola AI, GRC-04	Bab 11		3.046	32	32	3.110
Pengelola alat, GRC-05	Bab 14		500	1.000	1.000	2.500
Jumlah jam			**6.873**	**3.299**	**3.299**	**13.471**
Nilai, juta rupiah	Rp60.000 per jam		**412,38**	**197,94**	**197,94**	**808,26**

Membaca Beban Jam

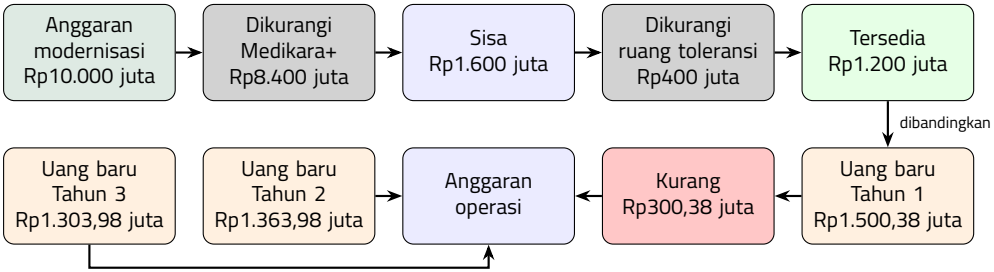
- 3.327 jam Tahun 1 berada di dalam GRC-01, senilai Rp199,62 juta, atau 27,7 persen.
- 6.873 jam setara 3,58 orang penuh waktu pada 1.920 jam kerja per tahun.
- 2.400 jam tersebar pada 4.800 karyawan, sehingga kelompok kerja menanggung 4.473 jam.
- Bila jatuh pada tim platform 6 orang, 38,8 persen kapasitasnya habis.
- Hemat 368 + 384 = 752 jam per tahun, tidak dikurangkan sebelum jadwal diubah.

Baris yang Sengaja Tidak Dijumlahkan

Baris	Nilai	Asal	Alasan
Rencana asurans	1.800 jam, Rp108 juta per tahun	Bab 12	Kapasitas yang sudah ada
Laporan satu halaman	384 jam, Rp23,04 juta per tahun	Bab 13	Menggantikan 768 jam
Lisensi AI-01	Rp150 juta per tahun	Bab 11	Belum diputuskan
Pemeriksaan AI-01 penuh	8.000 jam, Rp480 juta per tahun	Bab 11	Dihitung sebelum perluasan
Dukungan dalam negeri	Rp300 juta per tahun	Bab 7, Bab 9	Keputusan terpisah
Investasi Medikara+	Rp8.400 juta	Bab 2	Program lain

Audit Tahun 1: 600 + 480 + 240 + 120 = 1.440 jam. Tahun 2: 480 + 240 + 200 + 320 + 200 = 1.440 jam.

Uang Baru Terhadap Rp10 Miliar



Analogi: tabungan renovasi membayar atap baru, bukan tagihan listrik setiap bulan.

Tiga Konsekuensi Anggaran

PRADITA University

- Peta jalan tidak muat: Rp8.400 juta + Rp4.976,60 juta = Rp13.376,60 juta.
- Usulan: Rp1.200 juta dari sisa modernisasi, Rp300,38 juta dari operasi 2027.
- Rp4.976,60 juta hanya Rp23,40 juta di bawah batas Rp5 miliar.
- Dengan lisensi AI-01, jumlahnya Rp5.276,60 juta, sehingga dewan komisaris ikut.
- Rp60 miliar pada IT40513 adalah pagu lima tahun pada pengandaian lain. Rp10 miliar bukan barisnya.

Apakah Biayanya Sepadan?

Harapan kerugian	Sebelum	Sesudah	Turun	Asal
R-01 dengan AC-01 penuh	Rp100 juta	Rp25 juta	Rp75 juta	Bab 5
R-05 dengan opsi B	Rp200 juta	Rp40 juta	Rp160 juta	Bab 10
R-10 dengan uji ekspor	Rp80 juta	Rp30 juta	Rp50 juta	Bab 9
Jumlah	**Rp380 juta**	**Rp95 juta**	**Rp285 juta**	

- Tidak: Rp855 juta dalam tiga tahun, atau 17,2 persen dari biaya penuh.
- Pembelaan: batas 2 persen, kewajiban K-01, K-02, K-04, K-05, cedera pasien, syarat K2 dan P8.

Indikator sebagai Ukuran Keberhasilan

PRADITA University

Kode	Pemilik tindakan	Oktober 2026	Sasaran	Inisiatif
IK-01	Kepala operasi TI	1 akun, merah	0 akun	GRC-02
IK-02	Kepala operasi TI	0 akun, hijau	0 akun	GRC-02
IK-03	Kepala operasi TI	100 menit, kuning	Paling lama 90 menit	GRC-03, GRC-08
IK-04	Kepala risiko	1 skenario, merah	0 skenario	GRC-03
IK-05	Fungsi kepatuhan	0 baris, hijau	0 baris	GRC-01, GRC-07
IK-06	Pimpinan klinis	0 laporan, hijau	0 laporan	GRC-04
IK-07	Kepala operasi TI	95 persen, hijau	Minimal 95; TA-01 100	GRC-02
IK-08	Kepala operasi TI	83,33 persen, merah	100 persen	GRC-03, GRC-08
IK-09	Petugas pelindungan data	100 persen, hijau	100 persen	GRC-01
IK-10	Pemilik tiap temuan	90 persen, hijau	Minimal 90 persen	GRC-02, GRC-10
IK-11	Petugas pelindungan data	Tidak berlaku	100 persen	GRC-01
IK-12	Kepala pendaftaran	28 menit, kuning	Paling lama 25 menit	Dipantau GRC-11

IK-12 tidak diklaim sebagai hasil peta jalan GRC.

Kasus Medikara: Perpanjangan TA-01

- Tenggat 30 hari lewat. Status: selesai menurut manajemen, belum lolos uji ulang.
- Tenggat baru: tanggal acuan 31 Maret 2027. Kriteria 120, 60, dan 30 tidak berubah.
- Alasan: 60 catatan memerlukan 5 rumah sakit selama 12 bulan.
- Harga: Rp28,75 juta, bukan Rp25 juta per tahun, atau Rp1,25 juta selama 4 bulan.
- Direksi menerima risiko sisa secara tertulis. Tidak ada catatan susulan.

Manajemen Perubahan

- Anggaran kepatuhan: orang menimbang biaya dan manfaat, dan kesediaannya terbatas.
- Analogi antrean: jalur resmi yang lambat mendorong jalan pintas.
- Persetujuan 12 hari menjadi 2 hari: tunggu berkurang 300 hari per bulan.
- Dari 10 temuan selesai, 9 lolos uji ulang: IK-10 memakai 90 persen.
- G-04 menunggu sampai bulan 30, dengan persetujuan tertulis pemilik SIMRS.

Pertanyaan Direksi dan Jawaban C4

Pertanyaan	Bukti	Jawaban
Mengapa sekarang?	3 indikator merah; TA-01 lewat tenggat; R-05 10 persen	Harga menunggu sekitar Rp40 juta per triwulan
Berapa biayanya?	Tabel biaya dan tabel jam	Rp4.976,60 juta penuh; Rp4.168,34 juta uang baru
Dari mana uangnya?	Sisa modernisasi Rp1.200 juta	Kurang Rp300,38 juta; sisanya operasi
Bagaimana tahu berhasil?	IK-01 sampai IK-12; asurans	Gerbang hasil, diuji audit internal
Apa yang tetap berisiko?	R-02, R-04, R-07	Pemilik dan tanggal tinjau tercatat

Bila Anggaran Dipotong

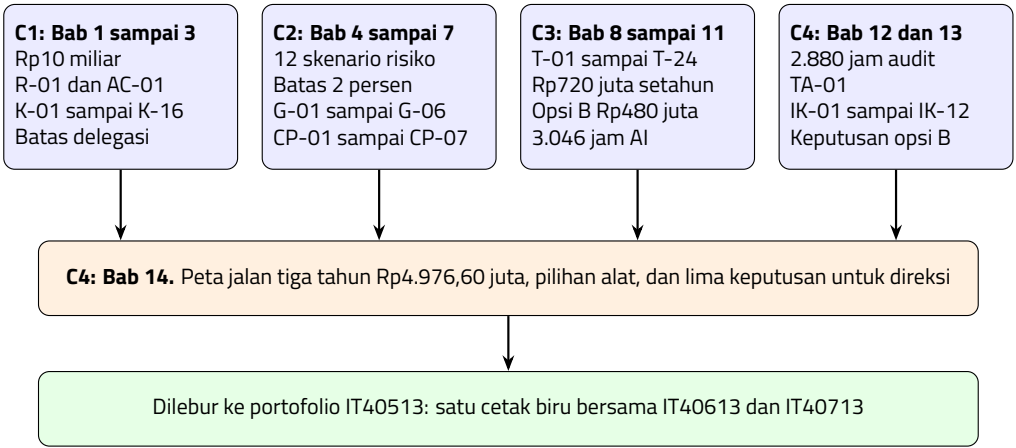
Pilihan	Hemat, juta	Akibat	Putusan
GRC-08 digeser ke Tahun 2	180	Audit pemulihan tanpa hasil latihan	Dipilih
Alat alternatif 6 bulan lebih lambat	120	AI-06 lebih lama tanpa alternatif	Dipilih
GRC-06 digeser setahun	60	R-10 tetap Rp80 juta; K-05 tetap	Ditolak
Tahap kedua opsi B dibatalkan	180	R-05 tetap 10 persen	Ditolak
AC-01 dikurangi	60	TA-01 dan syarat P1 gagal	Ditolak

Sisa Rp0,38 juta diserap operasi. Total turun menjadi Rp4.856,60 juta. Uang baru Tahun 2 naik menjadi Rp1.543,98 juta.

Titik Temu Empat Mata Kuliah

Mata kuliah	Titik temu	Syarat	Bulan
IT40513	P1 selesai Maret 2027	TA-01 lolos uji ulang	4
IT40513	K2 Oktober 2027	Penilaian vendor selesai, GRC-07	11
IT40513	K3 Maret 2029, K4 Oktober 2029	Uji pemulihan pada rumah sakit yang pindah	28, 35
IT40613	P8 portal dan API mitra, Januari 2029	Penilaian vendor; KB-05; KB-09	26
IT40713	Rancangan cloud dan pemulihan	BIA, RTO sistem 120 menit, profil target	1 sampai 12

Asal Angka dari C1 sampai C4



Kasus Medikara: Lima Keputusan

PRADITA University

1. Setujui peta jalan: Rp4.976,60 juta biaya penuh, Rp4.168,34 juta uang baru.
2. Sumber dana: Rp1.200 juta sisa modernisasi, Rp300,38 juta operasi 2027, lalu operasi.
3. Tahan tahap kedua opsi B Rp180 juta sampai uji ulang akhir Januari 2027.
4. Catat perpanjangan TA-01 sampai tanggal acuan 31 Maret 2027.
5. Pakai spreadsheet terstruktur pada Tahun 1, gerbang alat November 2027.

Aktivitas: Peta Jalan dan Gladi C4

PRADITA University

1. Satukan identitas, lalu baca isi tiap acuan satu kontrol.
2. Susun tiga tahun: ketergantungan, biaya, pemilik, indikator, gerbang.
3. Pisahkan jam di dalam biaya lain, biaya penuh, dan uang baru.
4. Bandingkan alat: syarat wajib, biaya sama periode, uji bobot.
5. Selaraskan dengan tiga mata kuliah lain, lalu gladi rapat direksi.

Luaran menutup C4 menjelang UAS, lalu dilebur ke IT40513. Penilaian: keterlacakan 30, urutan dan biaya 30, alat 20, pembelaan 20 persen. Data organisasi nyata wajib seizin dan dianonimkan. Berkas: `sources/chapter14/README.md`.

Ringkasan

- AC-01 berkontribusi pada banyak acuan, tetapi tidak memenuhi seluruh isinya.
- Alat dipilih sesudah definisi stabil. Jalur bertahap Rp230 juta.
- Peta jalan Rp4.976,60 juta dan 13.471 jam tidak muat dalam sisa Rp1.200 juta.
- Pembelaannya batas risiko, kewajiban, keselamatan, dan syarat lintas mata kuliah.
- Tata kelola nyata ketika tanggung jawab, sumber daya, dan bukti bertemu dalam keputusan.

Latihan

PRADITA University

1. Organisasi dengan 300 karyawan ingin membeli platform GRC yang mahal. Argumen apa yang mendukung dan menolak keputusan itu?
2. Jelaskan gagasan “satu kontrol untuk banyak kewajiban” dengan contoh kontrol peninjauan hak akses yang sekaligus memenuhi UU PDP, ISO/IEC 27001, dan NIST CSF.
3. Susun tiga inisiatif *quick win* GRC untuk Medikara Health pada enam bulan pertama, lalu jelaskan alasan urutannya.

Bacaan dan Berkas Pendukung

PRADITA University

- NIST CSF 2.0
- NIST OSCAL
- Papazafeiropoulou dan Spanaki, GRC IS
- Beautement dan rekan, The Compliance Budget
- `sources/chapter14/README.md`